

THREAT ACTOR PROFILE

APT28 — Fancy Bear

GRU Unit 26165 | Russian Military Intelligence

Profile Reference: TAP-2026-APT28 | Classification: TLP:WHITE

Field	Details
Also Known As	Fancy Bear, Sofacy, Sednit, STRONTIUM, Forest Blizzard, Pawn Storm, FROZENLAKE
Attribution	Russian GRU — 85th GTsSS, Military Unit 26165
Active Since	2004 (publicly reported from 2007)
Motivation	Espionage, intelligence collection, influence operations — geopolitical, not financial
Threat Level	CRITICAL
MITRE Group ID	G0007 — attack.mitre.org/groups/G0007
Profile Date	June 2026

1. Who Is APT28?

APT28 is one of the most sophisticated and long-running state-sponsored cyber espionage groups in the world. Widely attributed to Russia's Main Directorate of the General Staff (GRU), specifically Unit 26165, the group has been conducting cyber operations in support of Russian military and strategic intelligence objectives since at least 2004.

Unlike financially motivated threat actors, APT28 operates exclusively in service of geopolitical goals — collecting intelligence, stealing sensitive military and political information, and conducting influence operations that align with Russia's strategic interests. They are patient, resourceful, and highly adaptive, having evolved their tooling and techniques significantly over two decades of operation.

In 2018, the US Department of Justice indicted five GRU Unit 26165 officers for cyber operations conducted between 2014 and 2018, targeting organisations including the World Anti-Doping Agency (WADA), the US Anti-Doping Agency, the Organisation for the Prohibition of Chemical Weapons (OPCW), and a US nuclear facility. This indictment provided the clearest public confirmation of APT28's government attribution to date.

As of 2025, APT28 remains highly active, with ongoing campaigns targeting European entities, NATO member organisations, and organisations involved in supporting Ukraine, demonstrating that the group's operational tempo has only increased since the 2022 Russian invasion of Ukraine.

20+ Years Active since 2004	GRU Unit 26165 — Russia	50+ TTPs MITRE ATT&CK mapped	Espionage Not financially motivated
---------------------------------------	-----------------------------------	--	---

2. Who Do They Target?

APT28 targets organisations that can provide political, military, or strategic intelligence value to the Russian state. Their targeting is opportunistic within a defined strategic scope — they go where Russian intelligence interests point, not where money is.

Sector	Why APT28 Targets Them
Government agencies	Political intelligence, diplomatic communications, policy decisions
Military & defence contractors	Weapons systems, operational planning, troop movements, defence technology
Political parties & elections	Influence operations — leaking compromising material to affect election outcomes
NATO member organisations	Alliance intelligence, member state capabilities, collective defence planning
Critical infrastructure	Energy, telecommunications — strategic disruption capability
Ukraine-support organisations	Aid logistics, military support tracking — directly linked to the 2022 conflict
Think tanks & NGOs	Policy research, human rights orgs, organisations critical of the Russian government
Media organisations	Journalist sources, editorial communications, influence over public narrative

3. Top 10 Tactics, Techniques & Procedures (TTPs)

The following techniques represent APT28's most consistently observed and impactful TTPs, mapped to the MITRE ATT&CK framework. These are the behaviours a SOC analyst should be hunting for in environments at risk of APT28 targeting.

#	Technique ID	Technique Name	Tactic	How APT28 Uses It
1	T1566.001	Spearpishing	Initial Access	Sends highly targeted

		Attachment		emails with malicious Office documents or PDFs disguised as legitimate communications
2	T1110.003	Password Spraying	Credential Access	Tries a small number of common passwords across many accounts — avoids lockouts while compromising accounts at scale
3	T1557	Adversary-in-the-Middle	Credential Access	Deploys phishing proxies that intercept MFA tokens and session cookies — bypassing multi-factor authentication entirely
4	T1078	Valid Accounts	Defence Evasion	Uses stolen credentials to authenticate as legitimate users — blends in with normal traffic, extremely hard to detect
5	T1053.005	Scheduled Task	Persistence	Creates scheduled tasks to maintain access and execute payloads after reboots — same technique seen in the LockBit IR case
6	T1071.001	Web Protocols C2	Command & Control	Uses standard HTTP/HTTPS for C2 communications to blend with normal web traffic and bypass firewall rules
7	T1083	File & Directory Discovery	Discovery	Enumerates file systems to locate sensitive documents, credentials, and configuration files worth exfiltrating
8	T1048	Exfiltration Over Alternative Protocol	Exfiltration	Exfiltrates stolen data via non-standard protocols (FTP, DNS) to evade data loss prevention tools
9	T1027	Obfuscated Files or Info	Defence Evasion	Encodes and obfuscates malware payloads and scripts to evade antivirus and EDR detection
10	T1021.001	Remote Desktop Protocol	Lateral Movement	Uses RDP with stolen credentials to move laterally across networks — especially effective in Windows enterprise environments

4. Notable & Unique Techniques

Beyond their core TTPs, APT28 has demonstrated several distinctive techniques that set them apart from other threat actors:

Nearest Neighbour Attack

Documented in November 2024, this technique involves compromising a building or organisation physically adjacent to the target, then pivoting through their Wi-Fi network to reach the intended victim. This demonstrates APT28's willingness to conduct close-access operations and use indirect paths when direct network access is blocked. The technique effectively extends their reach beyond internet-facing systems into physically air-gapped or restricted network segments.

Adversary-in-the-Middle (AiTM) Phishing

APT28 operates phishing pages that act as transparent proxies — when a victim enters their credentials, the page simultaneously authenticates to the real service and captures the resulting session token. This allows APT28 to bypass MFA entirely, since they steal the authenticated session rather than the password. This is a critical finding for any organisation that considers MFA alone sufficient protection.

Living off the Land

Like the LockBit affiliate in the IR report, APT28 heavily favours built-in Windows tools — PowerShell, WMI, scheduled tasks, and RDP — over custom malware. This makes detection significantly harder because the tools themselves are legitimate. The malicious activity is only visible in the context of how and when the tools are used.

5. Detection Opportunities

The following detection rules, mapped to Splunk SPL and the home lab SIEM built in this portfolio, would identify APT28 activity at multiple stages of their attack chain:

TTP	What to Look For	Splunk SPL	EventCode	Priority
Password Spraying	Many failed logins across different accounts from same source	index=main EventCode=4625 stats count by src, Account_Name where count > 5	4625	CRITICAL
Scheduled Task Persistence	New scheduled task created — especially outside business	index=main EventCode=4698	4698	HIGH

	hours			
Lateral Movement via RDP	Successful logins using Type 10 logon from unexpected IPs	index=main EventCode=4624 Logon_Type=10	4624	HIGH
Suspicious Process Spawning	PowerShell or cmd.exe launched by unusual parent process	EventCode=4688 parent spawning powershell/cmd	4688	HIGH
Valid Account Abuse	Logons at unusual hours or from unusual geolocations	index=main EventCode=4624 Logon_Type=3 stats by Account_Name, src	4624	MEDIUM

All five SPL queries above are variants of detection rules built and validated in the home lab SIEM environment documented in Project 1 of this portfolio.

6. MITRE ATT&CK Full Technique Mapping

The following table maps APT28's techniques across all ATT&CK tactics. A complete Navigator layer file (apt28-navigator-layer.json) accompanies this profile and can be loaded into the ATT&CK Navigator at mitre-attack.github.io/attack-navigator to visualise the full technique heatmap.

Tactic	Technique ID	Technique Name
Initial Access	T1566.001 / T1566.002	Spearphishing Attachment / Spearphishing Link
Initial Access	T1078	Valid Accounts — using stolen credentials for initial entry
Execution	T1059.001	PowerShell — scripted execution of payloads
Execution	T1059.003	Windows Command Shell
Persistence	T1053.005	Scheduled Task — survives reboots
Persistence	T1547.001	Registry Run Keys — malware auto-starts on login
Privilege Escalation	T1134	Access Token Manipulation — used CVE-2015-1701 to access SYSTEM token
Defence Evasion	T1027	Obfuscated Files — encodes payloads to evade AV
Defence Evasion	T1078	Valid Accounts — legitimate credentials evade detection
Credential Access	T1110.003	Password Spraying — low-and-slow credential attacks

Credential Access	T1557	Adversary-in-the-Middle — steals MFA session tokens
Discovery	T1083	File & Directory Discovery — locates sensitive files
Discovery	T1018	Remote System Discovery — maps the network
Lateral Movement	T1021.001	RDP — moves between machines with stolen credentials
Lateral Movement	T1021.002	SMB/Admin Shares — lateral movement over file shares
Exfiltration	T1048	Exfiltration Over Alternative Protocol — FTP, DNS
Command & Control	T1071.001	Web Protocols — C2 over HTTP/HTTPS to blend in

7. Defensive Recommendations

The following recommendations are specifically tailored to counter APT28's known TTPs. Organisations in sectors targeted by APT28 should treat these as priority hardening actions:

Immediately actionable

- Deploy phishing-resistant MFA (hardware tokens or passkeys) — standard TOTP-based MFA is bypassed by APT28's AiTM phishing technique
- Enable audit logging for all authentication events (EventCodes 4624, 4625, 4648) and forward to a SIEM
- Block known APT28 infrastructure at the firewall — CISA advisories publish current IOCs
- Enforce strong password policies and monitor for password spraying patterns (>5 failures across accounts from same source)

Within 30 days

- Deploy endpoint detection with parent-child process monitoring — catches PowerShell and cmd.exe spawned by unusual parents
- Implement network segmentation to limit lateral movement — RDP should not be accessible between all endpoints
- Enable scheduled task creation alerts (EventCode 4698) in your SIEM — APT28 consistently uses this for persistence
- Conduct phishing awareness training with specific focus on credential harvesting pages — teach users to verify URLs before entering passwords

Strategic

- Assume stolen credentials are in use — monitor for logins at unusual hours, from unusual locations, or with unusual patterns even when credentials are valid
- Treat MFA as a layer, not a solution — AiTM attacks mean MFA is necessary but not sufficient alone
- Review Wi-Fi network security and physical perimeter — the Nearest Neighbour attack shows APT28 will exploit adjacent networks

8. Analyst Notes & Key Takeaways

APT28 is not a new or emerging threat — they are a mature, well-resourced, state-backed operation that has been active for over 20 years. What makes them particularly dangerous is not technical sophistication alone, but their patience, their use of legitimate tools, and their ability to operate inside networks for extended periods without triggering alerts.

Three observations stand out from this analysis that are directly relevant to SOC operations:

- MFA is not a silver bullet. APT28's AiTM technique specifically defeats standard MFA by stealing the authenticated session. Phishing-resistant MFA (FIDO2/passkeys) is the only reliable mitigation for this specific technique.
- Living off the land makes them hard to catch. APT28 heavily uses built-in Windows tools — the same tools your admins use every day. Detection requires behavioural analysis (context of how tools are used) not just tool detection (what tools are present).
- The Nearest Neighbour attack redefines the perimeter. If an adjacent organisation is less secure, APT28 will use it as a stepping stone. Network security can no longer be considered in isolation from the physical environment.

The detection rules documented in Section 5 of this profile are all operational in the home lab SIEM built in Project 1 of this portfolio. The connection between this threat actor profile and the SIEM lab demonstrates the full blue team workflow: understand the threat, build detections, validate them against simulated attack traffic.

End of Profile — TAP-2026-APT28

Sources: MITRE ATT&CK G0007 | CISA Advisory AA25-141A | The DFIR Report | SOCRadar Dark Web Profile: APT28 (2026)